

ENCUESTA INTEGRAL DE CIBERSEGURIDAD Y GOBERNANZA IA

Modelo de Evaluación de Madurez Organizacional

Versión: 2.0

Fecha: Enero 2026

Clasificación: Uso Interno / Confidencial

Público Objetivo: Responsables de Ciberseguridad, CISOs, Directores de TI, Responsables de Gobernanza IA, Líderes de Negocio

INSTRUCCIONES PRELIMINARES

Esta encuesta evalúa **cinco dimensiones críticas de seguridad y gobernanza IA** en su organización:

1. GOBERNANZA Y RIESGO (GOVERN - NIST AI RMF)
2. MAPEO DE CONTEXTO E IMPACTO (MAP - NIST AI RMF)
3. MEDICIÓN Y MÉTRICAS (MEASURE - NIST AI RMF)
4. VULNERABILIDADES Y PENTESTING
5. SIEM Y CAPACITACIÓN DE EMPLEADOS

Escala de Madurez Estándar (aplica a todas las preguntas salvo especificado):

- Nivel 1 (Ad-hoc / Inexistente): No documentado, sin procesos formales, reactividad total
- Nivel 2 (Incipiente / Repetible): Procesos iniciales, inconsistentes, documentación parcial
- Nivel 3 (Definido / Estándar): Procesos documentados, aplicados organizacionalmente, roles claros
- Nivel 4 (Cuantificado / Gestionado): Métricas y KPIs monitoreados, datos-driven, mejora continua
- Nivel 5 (Optimizado / Proactivo): Automatización, predicción, innovación, adaptación ágil a amenazas

Tiempo Estimado: 45-60 minutos

Confidencialidad: Las respuestas son confidenciales y agregadas únicamente con consentimiento explícito

MÓDULO 1: GOBERNANZA Y RIESGO IA (GOVERN)

Sección 1.1: Políticas, Procesos, Procedimientos

Pregunta 1.1.1: ¿Existe una política formal de Inteligencia Artificial y Ciberseguridad documentada y aprobada por el Comité de Dirección?

- ☐ Nivel 1: No existe política formal
- ☐ Nivel 2: Existe borradores, pero sin aprobación ni distribución
- ☐ Nivel 3: Política aprobada, comunicada, disponible en portal de compliance
- ☐ Nivel 4: Política con revisiones trimestrales, métricas de cumplimiento
- ☐ Nivel 5: Política adaptativa, actualizada automáticamente según cambios regulatorios (alertas NIS2, EU AI Act)

Pregunta 1.1.2: ¿Cómo documentan y gestionan el **apetito de riesgo** (risk tolerance) en IA?

- ☐ Nivel 1: No documentado; decisiones ad-hoc caso a caso
- ☐ Nivel 2: Tolerancia de riesgo verbal, comunicada informalmente
- ☐ Nivel 3: Escalas RAG (Rojo-Amarillo-Verde) definidas por categoría (accuracy, bias, security, privacy)
- ☐ Nivel 4: Tolerancia cuantificada (p.ej., "Sesgo <5% en modelos de decisión crítica"); monitoreada mensualmente
- ☐ Nivel 5: Tolerancia dinámica, ajustada según riesgo portfolio y cambios market/regulatorio

Pregunta 1.1.3: ¿Existe un proceso formal de **inventario de sistemas IA** (qué modelos, dónde, quién es propietario)?

- ☐ Nivel 1: No existe inventario; "desconocemos cuántos sistemas IA tenemos"
- ☐ Nivel 2: Inventario parcial (IT awareness, pero no negocio)
- ☐ Nivel 3: Inventario centralizado, completo, con propietario, risk tier asignado
- ☐ Nivel 4: Inventario automatizado con actualizaciones en tiempo real, linked a asset management
- ☐ Nivel 5: Inventario inteligente con predicción de ciclo vida, deprecation planning automático

Pregunta 1.1.4: ¿Qué mecanismos existen para **escalada de riesgos IA hasta Board/C-suite**?

- ☐ Nivel 1: No existe; CISOs/AI leads no reportan a junta
- ☐ Nivel 2: Reportes ad-hoc, sin estructura; frecuencia irregular
- ☐ Nivel 3: Reportes trimestrales formales, Risk Committee, agenda pre-definida
- ☐ Nivel 4: Dashboard ejecutivo con KPIs en tiempo real, alertas automáticas si risk > tolerance
- ☐ Nivel 5: Gobernanza predictiva; alertas sobre riesgos emergentes antes de materialización

Sección 1.2: Accountability y Estructuras Organizacionales

Pregunta 1.2.1: ¿Existe una estructura de **RACI (Responsible, Accountable, Consulted, Informed)** **formalizada** para decisiones de seguridad IA?

- ☐ Nivel 1: Roles no definidos; "depende de quién esté disponible"
- ☐ Nivel 2: Roles parcialmente definidos, sin documentación
- ☐ Nivel 3: RACI documentada, publicada, ampliamente conocida (survey muestra >70% comprensión)
- ☐ Nivel 4: RACI con métricas de eficacia (p.ej., tiempo escalada, resolución), auditoría semestral
- ☐ Nivel 5: RACI dinámico, adaptado por risk tier; auto-evalúa y optimiza

Pregunta 1.2.2: ¿Cómo garantizan **independencia** entre equipos de desarrollo y testing de seguridad?

- ☐ Nivel 1: Misma persona desarrolla y testea ("seguridad integrada")
- ☐ Nivel 2: Testing separado, pero reporting interno a desarrollo; conflicto interés potencial
- ☐ Nivel 3: Equipos independientes, reporting a Chief Security /Compliance Officer (no a desarrollo)
- ☐ Nivel 4: Testing independiente + auditoría externa anual para sistemas high-risk; results verificados externamente
- ☐ Nivel 5: Testing independiente con rotación de auditor externo, red teaming periódico

Pregunta 1.2.3: ¿Cuál es la **frecuencia y cobertura de capacitación** en ciberseguridad y gobernanza IA?

- ☐ Nivel 1: No hay capacitación formal
- ☐ Nivel 2: Capacitación ad-hoc, orientada a IT solamente
- ☐ Nivel 3: Capacitación anual mandatoria para IT + roles críticos; contenido documentado
- ☐ Nivel 4: Capacitación trimestral con assessment de conocimiento; seguimiento de roles high-risk
- ☐ Nivel 5: Capacitación adaptativa, micro-learning continuo basado en riesgo individual; 90%+ de cobertura

Pregunta 1.2.4: ¿Existe un **Comité de Gobernanza IA** con representación interdisciplinaria (legal, técnico, negocio, ética)?

- ☐ Nivel 1: No existe comité
- ☐ Nivel 2: Comité informal, ocasional, sin acta
- ☐ Nivel 3: Comité formal, reuniones mensuales/trimestrales, actas, decisiones documentadas
- ☐ Nivel 4: Comité con KPIs, dashboard, decisiones tied a business impact
- ☐ Nivel 5: Comité predictivo, anticipation de riesgos; integración con board committees

Sección 1.3: Diversidad, Equidad, Inclusión (DEIA) y Configuraciones Humano-IA

Pregunta 1.3.1: ¿Cuál es la **composición demográfica e interdisciplinaria** de equipos de seguridad/IA?

- ☐ Nivel 1: Homogéneo; <50% diversidad (gender, ethnicity, background expertise)
- ☐ Nivel 2: Diversidad <70% (representado en reclutamiento, pero no en decisiones)
- ☐ Nivel 3: Diversidad 70%+ documented; roles interdisciplinarios (legal, psicología, ingeniería, ciencias sociales)
- ☐ Nivel 4: Métricas de diversidad, auditoría anual, decisiones inclusivas documentadas
- ☐ Nivel 5: Diversidad por diseño; automatización de inclusión (algoritmos de contratación fair, compensación equitativa)

Pregunta 1.3.2: En sistemas IA críticos, ¿cómo está **diferenciado el rol humano (oversight vs. operación)**?

- ☐ Nivel 1: No hay diferenciación; humans = algoritmo (100% automation)
- ☐ Nivel 2: Diferenciación vaga; "alguien revisa la salida del modelo"
- ☐ Nivel 3: Roles claramente documentados (p.ej., 70% automation, 30% human-in-loop); competencia de operadores definida
- ☐ Nivel 4: Human proficiency standards definidos y certificados; override capability documentada
- ☐ Nivel 5: Configuración dinámico; automation % ajusta según riesgo; humans upskilled continuamente

MÓDULO 2: MAPEO DE CONTEXTO E IMPACTO (MAP)

Sección 2.1: Contexto Establecido

Pregunta 2.1.1: ¿Documentan el **propósito intencional y beneficiarios** de cada sistema IA? (stakeholder mapping)

- ☐ Nivel 1: No documentado; "lo usamos porque es útil"
- ☐ Nivel 2: Documentación incompleta; propósito claro pero beneficiarios/impactados no identificados
- ☐ Nivel 3: Propósito + beneficiarios + comunidades potencialmente impactadas (negativas/positivas) documentados
- ☐ Nivel 4: Stakeholder mapping con análisis de impacto (cuantificado); consulta participativa documentada
- ☐ Nivel 5: Contexto vivo; stakeholder feedback loop continuo; ajustes de propósito según input

Pregunta 2.1.2: ¿Evalúan **alternativas no-IA** antes de deployar sistemas IA?

- ☐ Nivel 1: No; "necesitamos IA porque es moderno"
- ☐ Nivel 2: Evaluación superficial; bias hacia IA
- ☐ Nivel 3: Análisis formal de alternativas (manual, semi-automático); IA vs. no-IA documentado
- ☐ Nivel 4: Análisis costo-beneficio cuantificado; trade-offs (accuracy vs. transparency, eficiencia vs. fairness) documentados
- ☐ Nivel 5: Decisión optimizada; re-evaluación periódica; pivote a alternativas si IA no sirve

Pregunta 2.1.3: ¿Documentan **implicaciones legales y normativas** para cada sistema IA?

- ☐ Nivel 1: No; "IT se encarga de compliance"
- ☐ Nivel 2: Documentación general (GDPR, pero no LGPD, AI Act, NIS2)
- ☐ Nivel 3: Checklist normativo (GDPR, LOPD, EU AI Act, NIS2); requisitos mapeados a controles
- ☐ Nivel 4: Risk assessment normativo con calendarios de transposición (p.ej., "Art. 50 EU AI Act obligatorio agosto 2026")
- ☐ Nivel 5: Compliance predictivo; alertas automáticas sobre cambios regulatorios relevantes

Sección 2.2: Categorización de Sistemas IA

Pregunta 2.2.1: ¿Cómo **categorizan la tarea técnica** del sistema IA (clasificación, generación, recomendación, etc.)?

- ☐ Nivel 1: Sin categorización; "es un modelo"
- ☐ Nivel 2: Categorización informal; no documentada
- ☐ Nivel 3: Tarea técnica definida formalmente (p.ej., "clasificador binario para crédito"); límites conocimiento documentados
- ☐ Nivel 4: Taxonomía de tareas con perfil de riesgo por tipo (clasificadores = bajo riesgo, sistemas decisión crítica = alto riesgo)
- ☐ Nivel 5: Taxonomía automática basada en contexto; re-categorización si cambios de propósito

Pregunta 2.2.2: ¿Documentan **límites de conocimiento del modelo** (edge cases, out-of-distribution escenarios)?

- ☐ Nivel 1: No; asumen funcionamiento en todo contexto
- ☐ Nivel 2: Conocimiento de límites ad-hoc; no documentado formalmente
- ☐ Nivel 3: Edge cases identificados, documentados; fallback procedures definidas
- ☐ Nivel 4: Testing de OOD; métricas de performance en boundary conditions; degradation graceful
- ☐ Nivel 5: Predicción de boundary violations; auto-routing a manual si confidence bajo

Pregunta 2.2.3: ¿Cómo **especifican la configuración humano-IA** (% automation vs. % human-in-loop)?

- ☐ Nivel 1: No especificado; sistema es "black box"
- ☐ Nivel 2: Especificado verbalmente; no documentado
- ☐ Nivel 3: % Automation documentado por decisión (p.ej., "recomendación: 80% auto, 20% human review")
- ☐ Nivel 4: Override capability cuantificado; SLA para human response; audit de overrides
- ☐ Nivel 5: Configuración dinámica; % humans ajusta según confidence/risk; humans empowered con context

Sección 2.3: Riesgos Priorizados

Pregunta 2.3.1: ¿Utilizan un **Risk Matrix (Impact × Likelihood)** para priorizar riesgos IA?

- ☐ Nivel 1: No; "todos los riesgos son iguales"
- ☐ Nivel 2: Priorización informal; basada en intuición
- ☐ Nivel 3: Matriz formal (5×5 o similar); riesgos scored y ranked
- ☐ Nivel 4: Scoring con criterios definidos (impact: negligible/minor/moderate/major/critical); histórico de trends
- ☐ Nivel 5: Scoring dinámica; algoritmo ajusta pesos según cambios contexto/threat landscape

Pregunta 2.3.2: ¿Cómo identifican y **rastrean riesgos específicos de IA** (data poisoning, model extraction, prompt injection, drift)?

- ☐ Nivel 1: No; enfoque tradicional ciberseguridad solamente
- ☐ Nivel 2: Awareness de riesgos, pero sin catalog formal
- ☐ Nivel 3: Risk register con riesgos IA específicos (poisoning, extraction, drift); mapeados a MAP context
- ☐ Nivel 4: Risk catalog con scoring, propietarios, mitigation plans; trimestral update
- ☐ Nivel 5: Risk intelligence feed; amenazas emergentes detectadas y agregadas automáticamente

MÓDULO 3: MEDICIÓN Y MÉTRICAS (MEASURE)

Sección 3.1: Las Siete Características de Trustworthiness

Para cada pregunta de esta sección, use la escala:

- ☐ **No medido:** No existe métrica
- ☐ **Medido informalmente:** Existe métrica, pero sin rigor científico
- ☐ **Medido formalmente:** Métrica estandarizada, documentada, baseline establecido
- ☐ **Monitoreado continuamente:** Métrica con cadencia (diaria/semanal); alertas si excede threshold
- ☐ **Optimizado con feedback:** Métrica continuamente refinada basada en stakeholder feedback y emerging best practices

3.1.1 - Valid & Reliable (Validez y Confiabilidad)

¿Miden **accuracy, precision, recall, F1-score** desagregado por demografía (si relevante)?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (baseline $\geq 95\%$ accuracy, disparity $< 5\%$)
- ☐ Continuatamente monitoreado (alertas si accuracy $\downarrow > 2\%$)
- ☐ Optimizado con feedback

Detalle (si miden):

- Métrica primaria utilizada: ____
- **Frequency de medición:** ____
- **Quién es propietario:** ____
- Threshold de acción: _____

3.1.2 - Safe (Seguridad Operacional)

¿Miden **MTTR (Mean Time To Recover)**, incident response time, residual risk post-mitigation?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (target MTTR < 15 min)
- ☐ Continuatamente monitoreado (dashboard en tiempo real)
- ☐ Optimizado con feedback

Detalle (si miden):

- MTTR actual: __ (minutos/horas)
- **Threshold crítico:** __
- **System criticality tier:** __
- **Incidents SLA met last quarter:** __%

3.1.3 - Secure & Resilient (Seguridad y Resiliencia)

¿Miden **model extraction detection rate**, compromiso CI/CD, breach incidents?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (detección >95%, breach rate <0.1/1000 deployments)
- ☐ Continuamente monitoreado
- ☐ Optimizado

Detalle:

- Detection method: __
- **False positive rate:** __%
- Incidents de model theft (último año): _
- Remediation time average: _____

3.1.4 - Accountable & Transparent (Responsabilidad y Transparencia)

¿Miden **audit trail completeness (100%?)**, GDPR response time (<30 días)?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (audit trail 100%, response <30d)
- ☐ Continuamente monitoreado (compliance dashboard)
- ☐ Optimizado

Detalle:

- Audit trail completeness actual: __%
- **GDPR response time average:** __ días
- Transparency report frequency: __
- **Access request fulfillment rate:** __%

3.1.5 - Explainable & Interpretable (Explicabilidad)

¿Miden **SHAP/LIME coverage (%)**, explanation quality scores, feature importance audits?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (coverage >90%, quality $\geq 4/5$)
- ☐ Continuamente monitoreado
- ☐ Optimizado

Detalle:

- Explanation coverage actual: __%
- **Quality methodology:** __
- **User satisfaction with explanations:** __/5
- **Model types explicables:** __

3.1.6 - Privacy-Enhanced (Privacidad Mejorada)

¿Miden **data minimization ratio**, PET (Privacy-Enhancing Tech) implementation %, privacy incident rate?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (minimization >70%, PET >80%, 0 incidents)
- ☐ Continuamente monitoreado
- ☐ Optimizado

Detalle:

- Data minimization ratio actual: __%
- **PET technologies implemented:** ____
- Privacy breaches (último año): _
- GDPR Article 32 controls coverage: ____%

3.1.7 - Fair (Equidad - Bias Manejado)

¿Miden **demographic parity, equalized odds, disparate impact**, bias audit frequency?

- ☐ No medido
- ☐ Informalmente
- ☐ Formalmente (parity gap <5%, odds <3%, audit trimestral)
- ☐ Continuamente monitoreado (bias detection en producción)
- ☐ Optimizado (mitigation automática si bias detectado)

Detalle:

- Demographic groups evaluated: ____
- **Parity gap actual:** _%
- **Equalized odds gap:** __%
- **Bias audit last conducted:** __
- Bias training for teams: ☐ Sí ☐ No (frequency: __)

Sección 3.2: TEVV (Test, Evaluation, Validation, Verification)

Pregunta 3.2.1: ¿Realizan **pruebas pre-deployment** (TEVV) documentadas para sistemas IA?

- ☐ Nivel 1: No; "deployamos y aprendemos"
- ☐ Nivel 2: Testing ad-hoc; no documentado
- ☐ Nivel 3: Testing checklist formal; accuracy, bias, robustness, privacy, security evaluados
- ☐ Nivel 4: TEVV con coverage tracking; gate criteria definidos (p.ej., "no deploy si accuracy <95%")
- ☐ Nivel 5: TEVV automático; gate criteria dinámicos según risk; rollback automático si failures

Pregunta 3.2.2: ¿Qué **documentación estándar utilizan** (Model Cards, Data Sheets, FactSheets)?

- ☐ Nivel 1: No existe
- ☐ Nivel 2: Documentación incompleta; sin estructura estándar
- ☐ Nivel 3: Model Card template utilizado; completitud >80%
- ☐ Nivel 4: Model Card + Data Sheet + FactSheet; auditados externamente
- ☐ Nivel 5: Documentación viva; actualizada automáticamente con cada cambio modelo/data

Sección 3.3: Tracking de Riesgos Emergentes

Pregunta 3.3.1: ¿Tienen mecanismos para **captar feedback de usuarios finales** sobre riesgos?

- ☐ Nivel 1: No; sin canales
- ☐ Nivel 2: Feedback informal (conversaciones, emails anecdóticos)
- ☐ Nivel 3: Formulario formal; seguimiento documentado
- ☐ Nivel 4: Portal de feedback; tickets tracked, SLA response <48h
- ☐ Nivel 5: Feedback loop integrado; NLP analiza tendencias automáticamente

Pregunta 3.3.2: ¿Practican **red teaming continuo** (intentos periódicos de romper seguridad)?

- ☐ Nivel 1: No
- ☐ Nivel 2: Ad-hoc; cuando encuentran vulnerabilidades
- ☐ Nivel 3: Red teaming anual para sistemas críticos
- ☐ Nivel 4: Red teaming trimestral; documentado; findings actioned en <30 días
- ☐ Nivel 5: Red teaming continuous; automated + manual; resulta en roadmap de mejora

MÓDULO 4: VULNERABILIDADES Y PENETRATION TESTING

Sección 4.1: Evaluación de Vulnerabilidades

Pregunta 4.1.1: ¿Realizan **evaluaciones de vulnerabilidades** en infraestructura de IA/ciberseguridad?

- ☐ Nivel 1: No; "confiamos en vendedores"
- ☐ Nivel 2: Scanning esporádico; resultados no actioned
- ☐ Nivel 3: Scanning automatizado mensual; vulnerabilidades catalogadas en CMDB
- ☐ Nivel 4: Scanning continuo (semanal+); vulnerabilidades priorizado por CVSS + contexto business
- ☐ Nivel 5: Scanning inteligente + predictivo; predicción de vulnerabilidades pre-publicación CVE

Pregunta 4.1.2: ¿Cómo **gestionan el remediation de vulnerabilidades** (SLA, ownership, tracking)?

- ☐ Nivel 1: Ad-hoc; "cuando alguien se acuerda"
- ☐ Nivel 2: Tracking básico; sin SLA formal
- ☐ Nivel 3: SLA por CVSS score (Critical <7d, High <30d, Medium <90d); propietario asignado
- ☐ Nivel 4: SLA auditado; dashboard con compliance tracking; escalation si vencido
- ☐ Nivel 5: Remediation automático para vulnerabilidades low-risk; auto-patching con rollback capability

Pregunta 4.1.3: ¿Disponen de **visibilidad de activos y dependencias** (software BOM, ML-BOM)?

- ☐ Nivel 1: No; desconocen qué software/models tienen
- ☐ Nivel 2: Inventario parcial; sin dependencias mapeadas
- ☐ Nivel 3: Software BOM completo; dependencias documentadas (manual o semi-automático)
- ☐ Nivel 4: ML-BOM para sistemas IA (pre-trained models, training data, dependencias, cloud); actualizado automáticamente
- ☐ Nivel 5: Dynamic BOM; linked a supply chain intelligence; alerts si malicious packages detectados

Sección 4.2: Penetration Testing

Pregunta 4.2.1: ¿Realizan **Penetration Testing** (simular ataques reales)?

- ☐ Nivel 1: No; "confiamos en firewalls"
- ☐ Nivel 2: Pentesting ad-hoc; sin metodología formal
- ☐ Nivel 3: Pentesting anual para sistemas críticos; metodología estándar (PTES, NIST SP 800-115)
- ☐ Nivel 4: Pentesting trimestral (critical), semestral (high); con red teaming + black-box + white-box
- ☐ Nivel 5: PTaaS (Pentest as a Service); continuo; integrado en CI/CD; comporta feedback loop

Pregunta 4.2.2: ¿Utilizan **metodologías estándar** (PTES, NIST, OWASP, MITRE ATT&CK)?

- ☐ Nivel 1: No; "hacemos lo que nos parece"
- ☐ Nivel 2: Conscientes de estándares; aplicación inconsistente
- ☐ Nivel 3: Metodología seleccionada (PTES o NIST); documentada y comunicada
- ☐ Nivel 4: Multi-framework (PTES + MITRE ATT&CK mapping); threat emulation scenarios realista
- ☐ Nivel 5: Metodología adaptativa; evoluciona con threat landscape; continuous evolution framework

Pregunta 4.2.3: ¿Cómo **rastrean hallazgos de pentesting y miden remediación**?

- ☐ Nivel 1: No; resultados olvidados en reportes
- ☐ Nivel 2: Tracking manual; propietarios vagos
- ☐ Nivel 3: Findings registrados; SLA remediación; propietario claro
- ☐ Nivel 4: Dashboard con % closed, avg time-to-close, linked a risk register
- ☐ Nivel 5: Findings automáticamente linked a vulnerabilities detectadas; trending analysis; predictive remediation

Pregunta 4.2.4: ¿Evalúan **ataques específicos a IA** (data poisoning, model extraction, prompt injection, adversarial attacks)?

- ☐ Nivel 1: No; pentesting tradicional solamente
- ☐ Nivel 2: Conscientes, pero sin testing específico IA
- ☐ Nivel 3: Checklist de ataques IA; testing incluye algunos vectores (prompt injection, data poisoning)
- ☐ Nivel 4: Comprehensive IA attack testing (extraction, poisoning, adversarial, supply chain); documented scenarios
- ☐ Nivel 5: Continuous IA threat emulation; aligned con MITRE ATT&CK for AI; auto-remediation de vulnerabilidades

Pregunta 4.2.5: ¿Disponen de **independencia de quien ejecuta pentesting**?

- ☐ Nivel 1: Equipo interno solamente; potencial bias
- ☐ Nivel 2: Pentesting interno + occasional external
- ☐ Nivel 3: Pentesting externo anual (critical systems); independencia documentada
- ☐ Nivel 4: Mix interno (para feedback rápido) + externo (anual); third-party certified
- ☐ Nivel 5: Multiple external pentesters para evitar complacencia; red team vs. blue team competition

MÓDULO 5: SIEM Y CAPACITACIÓN DE EMPLEADOS

Sección 5.1: SIEM (Security Information & Event Management)

Pregunta 5.1.1: ¿Disponen de una **solución SIEM** centralizada para gestión de logs y eventos?

- ☐ Nivel 1: No; logs dispersos en sistemas locales
- ☐ Nivel 2: SIEM básico (log aggregation solamente); sin análisis correlación
- ☐ Nivel 3: SIEM con correlation rules; alertas para eventos predefinidos
- ☐ Nivel 4: SIEM avanzado (machine learning, anomaly detection); risk-based alerting; MTTR <2h
- ☐ Nivel 5: SIEM inteligente + EDR (Endpoint Detection & Response); predictivo; auto-response

Pregunta 5.1.2: ¿Qué **cobertura de fuentes de logs** tienen en SIEM?

- ☐ Nivel 1: <5 fuentes; principalmente servidores
- ☐ Nivel 2: 5-15 fuentes; network + servers, pero no endpoints/cloud
- ☐ Nivel 3: 15-30 fuentes; incluye endpoints, cloud, applications, network
- ☐ Nivel 4: 30+ fuentes; incluye mobile, IoT, third-party APIs; unified data lake
- ☐ Nivel 5: All-source integration; API-driven; new sources auto-discovered y onboarded

Pregunta 5.1.3: ¿Utilizan **Machine Learning** / **Anomaly Detection** en SIEM?

- ☐ Nivel 1: No; reglas manuales solamente
- ☐ Nivel 2: Piloto de ML; resultados inconsistentes
- ☐ Nivel 3: ML implementado; algún tuning de modelos
- ☐ Nivel 4: ML con feedback loop; modelos reentrenados mensualmente; low false-positive rate
- ☐ Nivel 5: Ensemble ML + SOAR automation; decision automation

Pregunta 5.1.4: ¿Cómo **gestionan y priorizan las alertas SIEM** para evitar alert fatigue?

- ☐ Nivel 1: Todas las alertas distribuidas a SOC; "apáguelas si es falsa"
- ☐ Nivel 2: Algunas reglas de correlación; aún alto volumen
- ☐ Nivel 3: Risk-based alerting; filtro de low-priority automático
- ☐ Nivel 4: Dynamic thresholding; alertas priorizadas por impact + likelihood; only high-confidence incidents
- ☐ Nivel 5: Conversational alerting; contexto explicado a analista; recommendations de acción automática

Pregunta 5.1.5: ¿Qué **SLA de respuesta a alertas SIEM** están definidas?

- ☐ Nivel 1: Sin SLA; "responden cuando pueden"
- ☐ Nivel 2: SLA informal; <4h para criticos
- ☐ Nivel 3: SLA formal (Critical <1h, High <4h, Medium <1d, Low <1w); documented
- ☐ Nivel 4: SLA met >95% time; tracked en dashboard; escalation automática si vencido
- ☐ Nivel 5: Dynamic SLA; ajustado por risk context; auto-response para low-risk incidents

Pregunta 5.1.6: ¿Integran SIEM con **incident response playbooks** de forma automática?

- ☐ Nivel 1: No; manual referencia a playbooks
- ☐ Nivel 2: Playbooks documentados; linkage manual a alerts
- ☐ Nivel 3: SIEM-playbook integration manual; respuesta semi-automática
- ☐ Nivel 4: SIEM triggers playbooks automáticamente; SOAR orchestration; human approval para high-risk
- ☐ Nivel 5: Full automation; playbooks ejecutan sin intervención; logging, escalation, feedback loop

Sección 5.2: Capacitación en Seguridad de Empleados

Pregunta 5.2.1: ¿Existe un **programa de Security Awareness Training (SAT)** formal y mandatorio?

- ☐ Nivel 1: No existe
- ☐ Nivel 2: Capacitación ad-hoc; no mandatoria
- ☐ Nivel 3: Capacitación anual mandatoria; todas las empleadas; contenido documentado
- ☐ Nivel 4: Capacitación trimestral adaptativa; rol-específica (IT vs. RH vs. finanzas); assessment de conocimiento
- ☐ Nivel 5: Micro-learning continuo; personalizado por risk profile del empleado; gamification + incentivos

Pregunta 5.2.2: ¿Cuál es la cobertura de empleados en SAT?

- ☐ Nivel 1: 0%
- ☐ Nivel 2: <30%
- ☐ Nivel 3: 70-90% (IT + roles críticos)
- ☐ Nivel 4: 90%+ (toda organización); tracked por departamento
- ☐ Nivel 5: 100%; incluyendo contractors, vendors, board

Pregunta 5.2.3: ¿Qué temas cubre la capacitación en seguridad?

- ☐ Nivel 1: Ninguno
- ☐ Nivel 2: Genéricos (phishing, passwords); sin contexto
- ☐ Nivel 3: Phishing, password hygiene, clean desk, incident reporting; role-specific modules
- ☐ Nivel 4: ++ Data handling, vendor security, social engineering, IA risks (bias, fairness, transparency), supply chain
- ☐ Nivel 5: Comprehensive; incluyendo threat intelligence, incident response drills, red teaming participation

Pregunta 5.2.4: ¿Realizan phishing simulations / tests?

- ☐ Nivel 1: No
- ☐ Nivel 2: Ad-hoc simulations; sin tracking formal
- ☐ Nivel 3: Mensual simulations; click rate tracked; avg 30-40% organización
- ☐ Nivel 4: Weekly simulations; tiered by role; click-rate trending; coaching para high-risk users
- ☐ Nivel 5: Behavioral coaching; click rate <10%; reporting rate >70%; gamified (badges, leaderboards)

Pregunta 5.2.5: ¿Cómo miden efectividad de SAT más allá de "completion rates"?

- ☐ Nivel 1: No miden
- ☐ Nivel 2: Completion rate solamente
- ☐ Nivel 3: + Phishing click rate, quiz scores, incident reporting rate
- ☐ Nivel 4: + Security incident reduction (YoY), behavior change metrics, risk score trending
- ☐ Nivel 5: + Advanced behavioral analytics (UEBA), predictive risk profile, ML-driven personalization

Pregunta 5.2.6: ¿Qué incentivos/consecuencias existen para comportamiento seguro/inseguro?

- ☐ Nivel 1: Ninguno
- ☐ Nivel 2: Castigo (disciplina) para brechas
- ☐ Nivel 3: Castigo + reconocimiento de "reportes de phishing"
- ☐ Nivel 4: Gamification (badges, puntos), reconocimiento público, carreras de team
- ☐ Nivel 5: Incentivos económicos (bonos), reconocimiento ejecutivo, connection a evaluación de performance

Pregunta 5.2.7: ¿Existe una **cultura de reporte segura** (reportar incidentes sin miedo a represalias)?

- ☐ Nivel 1: "Reportar = repercusiones"; sub-reporting alto
- ☐ Nivel 2: Cultura neutral; "reportar está permitido"
- ☐ Nivel 3: Comunicación clara de "no castigo"; anonymous reporting option; >50% report rate
- ☐ Nivel 4: Proactive encouragement; fast feedback ("gracias por reportar"); 70%+ report rate; visible leadership support
- ☐ Nivel 5: Psychological safety embedded; 90%+ report rate; reported threats fast-tracked a remediación visible

Pregunta 5.2.8: ¿Disponen de **entrenamiento especializado para roles de riesgo** (administradores, desarrolladores, RH)?

- ☐ Nivel 1: No
- ☐ Nivel 2: Genérico para IT; otros roles nada
- ☐ Nivel 3: IT + desarrolladores (secure coding); RH (social engineering)
- ☐ Nivel 4: Role matrix definida; cada rol con curriculum específico; certification
- ☐ Nivel 5: Continuous specialization; aligned con threat trends; vendor-specific trainings

MÓDULO 6: GOBERNANZA NIST AI RMF - MANAGE (Opcional pero Recomendado)

Sección 6.1: Orquestación de Riesgos y Respuesta

Pregunta 6.1.1: Para cada riesgo IA identificado, ¿tienen un **plan de mitigación documentado** (avoid/reduce/share/accept)?

- ☐ Nivel 1: No; "confiamos en que no pase"
- ☐ Nivel 2: Planes informales; algunos documentados
- ☐ Nivel 3: Plans documentados para riesgos >medio; propietario asignado
- ☐ Nivel 4: Plans cuantificados (p.ej., "reduce false positive de 10% a <5% en 30 días"); tracked
- ☐ Nivel 5: Plans dinámicos; auto-ajustan según effectiveness tracking; continuous optimization

Pregunta 6.1.2: ¿Cómo **validan que residual risk ≤ risk tolerance** antes de deployment?

- ☐ Nivel 1: No validan; "si no hay error crítico, deploy"
- ☐ Nivel 2: Validación manual; inconsistente
- ☐ Nivel 3: Checklist formal; gate criteria definidos; go/no-go decision
- ☐ Nivel 4: Gate criteria cuantificados linked to risk tolerance statement; auto-eval
- ☐ Nivel 5: Dynamic gates; ajustan según aprendizaje de deployments previos; predictive confidence

Pregunta 6.1.3: ¿Disponen de **Incident Playbooks** para riesgos IA (data breach, bias detection, safety failure)?

- ☐ Nivel 1: No
- ☐ Nivel 2: Playbooks genéricos solamente
- ☐ Nivel 3: >5 playbooks IA-específicos; owner, escalation path, SLA
- ☐ Nivel 4: Playbooks linked a SIEM; semi-automated execution
- ☐ Nivel 5: Fully automated; human oversight para high-risk; continuous improvement from incidents

SECCIÓN FINAL: KPIs Y SCORING

Tabla de Puntuación Consolidada

Módulo	Preguntas	Puntuación (1-5)	Comentarios
1. Gobernanza y Riesgo	1.1.1-1.3.2	—	
2. Mapeo de Contexto	2.1.1-2.3.2	—	
3. Medición y Métricas	3.1.1-3.3.2	—	
4. Vulnerabilidades y Pentesting	4.1.1-4.2.5	—	
5. SIEM y Capacitación	5.1.1-5.2.8	—	
6. MANAGE (Opcional)	6.1.1-6.1.3	—	
TOTAL MADUREZ ORGANIZACIONAL		— / 5.0	

Interpretación de Puntuación Global

- 1.0-1.5: Crítico – Recomendación urgente: roadmap de implementación inmediato
- 1.6-2.5: Incipiente – Procesos iniciales; inversión significativa requerida
- 2.6-3.5: Definido – Estándares establecidos; brechas en optimización
- 3.6-4.5: Cuantificado – Métricas y datos-driven; mejora continua en progreso
- 4.6-5.0: Optimizado – Liderazgo potencial; candidato para benchmarking global

Fin del Modelo de Encuesta

Documento de Evaluación Integral de Ciberseguridad y Gobernanza IA
Versión 2.0 | Enero 2026